



IT and Telecom Sector Frauds and Countermeasures



UNIVERSITY OF MADRAS
INSTITUTE OF DISTANCE EDUCATION

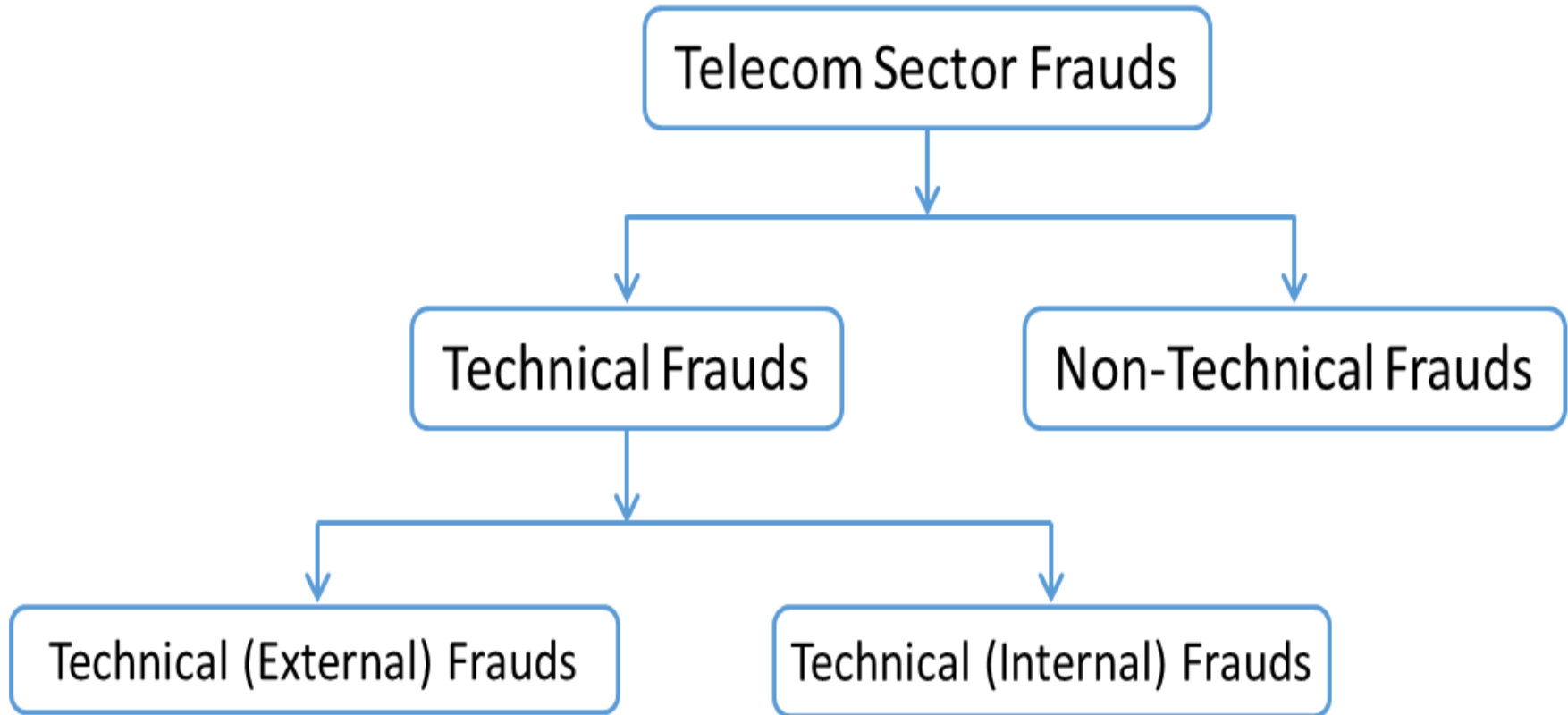
சென்னைப் பல்கலைக்கழகம்
தொலைதூரக் கல்வி நிறுவனம்

E.R. Ramesh, M.C.A., M.Sc., M.B.A.,

Day - 2



Telecommunication Frauds



Technical (External Frauds)

- Technical external frauds are committed **externally**, i.e. from **outside the network**, and are executed by **gaining access into the network system** using tools such as **hacking**.
- External frauds are usually **impersonal**, **opportunistic** and driven by **pure greed**.

Technical (External Frauds)

Examples:

- Use of **automatic telephone line isolators** to **penetrate** into the secret code / password for dynamic STD lock / Personal Identification code (PIN).
- Accessing the O&M port of the switch from **remote** and perform **opening & closing** of telephones or other services.

Technical (Internal Frauds)

- Technical Internal Frauds are committed by gaining **internal access** to the **network system**.
- **Internal frauds** can be very different from external frauds and are more often than not be driven by personal grudges or revenge.
- Internal fraud reveals the **breakdown of internal structures**, the **relationship between employer and employee**, and the **lack of internal controls** to provide **safety nets, checks and balances**.

Technical (Internal Frauds)

Examples:

- Manipulation of databases of **billing, charging, routing, subscribers, etc.**
- Changing the **equipment number** during preparation of **bulk billing** tape so that the **metering information** is transferred to the **spare equipment** number resulting in **non billing**.

Countermeasures for Internal Frauds

- There are various ways of **mitigating internal fraud**, such as:
 - ✓ Educate employees about **policies and procedures**, such as **strict monitoring, penalization, whistle blower hotlines**, etc.
 - ✓ Senior management should **own the company's internal controls** and keep a **tight reinforcement**. Senior management's attitude is crucial for setting the tone from the **top down**.

Countermeasures for Internal Frauds

- ✓ Using automated systems to check misuse of critical functions.
- ✓ Enabling deterrents by publicizing high profile fraud cases to deter would be fraudsters from committing fraud in future.
- ✓ Discuss: *Naming & Shaming*

Non-Technical Frauds

- **Non-technical frauds** are committed **without accessing or interfering** with the **network system**.
- One of **largest reason for revenue loss** of telecom companies is **fraudulent subscriptions**.



e.g., signing up with a bogus name, or no intention to pay.

Non-Technical Frauds

Examples:

- **Subscription Fraud** - Subscriber registers for phone service, makes up a large phone bill mostly through call selling and absconds before disconnection.

Countermeasures for Subscription Fraud

- The Department of Telecommunications has issued **proper subscriber verification** guidelines to the telecom companies.
- Revenue loss by reason of **fraudulent subscription** may be checked by following the governmental guidelines and implementing certain **basic precautionary measures** such as:
 - ✓ **Better screening and proper authentication of customers** and ensuring procedural integrity of dealership network

Countermeasures for Subscription Fraud

- ✓ **Telecom Enforcement, Resource and Monitoring Cells should be informed about the date of verification and uploading in relation to new connections.**
- ✓ **Documents submitted by the subscriber to the customer care executive should be verified with reference to the originals.**
- ✓ **Restrictions on roaming and international calls, placing limits on outstanding invoices.**

Non-Technical Frauds

Clip on fraud:

- The fraudster **accesses** the telecom infrastructure and **diverts the line** and **makes calls or sells services to others.**

Non-Technical Frauds

Call Forwarding:

- The **incoming calls** coming to line are **forwarded to a destination** such that the **calls are charged at much lesser rate** which otherwise would have been charged as per the distance.

Three Major Categories of Telecom Fraud

- Many telecom fraud schemes can be divided into **three broad categories**, based on who the **fraudsters** are targeting.

These categories are:

- **Traffic Pumping Schemes** – These schemes use “**access stimulation**” techniques to boost traffic to a high cost destination, which then shares the revenue with the fraudster.

Three Major Categories of Telecom Fraud

- **Schemes to Defraud Telecom Service Providers** - These schemes are the **most complicated**, and **exploit** telecom service providers using **SIP trunking**, **regulatory loopholes**, and more.
- **Schemes Conducted Over the Telephone** - Also known as "**Phone Fraud**," this category covers all types of general fraud that are **perpetrated over the telephone**.
- **E.g., Vishing.**

Premium Rate Numbers

- Many of the call scenarios featured in this report make use of premium rate numbers. These premium rate numbers are usually to a **high cost destination**.
- The **owner of the number** will **offer to share** the revenue generated from calls to these numbers with **anyone who sends them traffic**.

Premium Rate Numbers

- This means that a **fraudster who generates bogus or stimulated traffic** to that destination will **receive a kickback for each completed call.**
- E.g., attractive SMS on a specific service (**Dating / Friendship, Finance, Employment, Horoscope, etc.**)

Traffic Pumping Schemes

- The first major category of schemes of telecom fraud is called **traffic pumping or access stimulation**.
- These are **revenue sharing schemes**, characterized by fraudsters whom **greatly increase traffic to a specific high cost destination**. The destination then **shares a portion of their profits with the fraudster**.
- The call signature for these types of scenarios are **spikes in traffic to high cost destinations**.

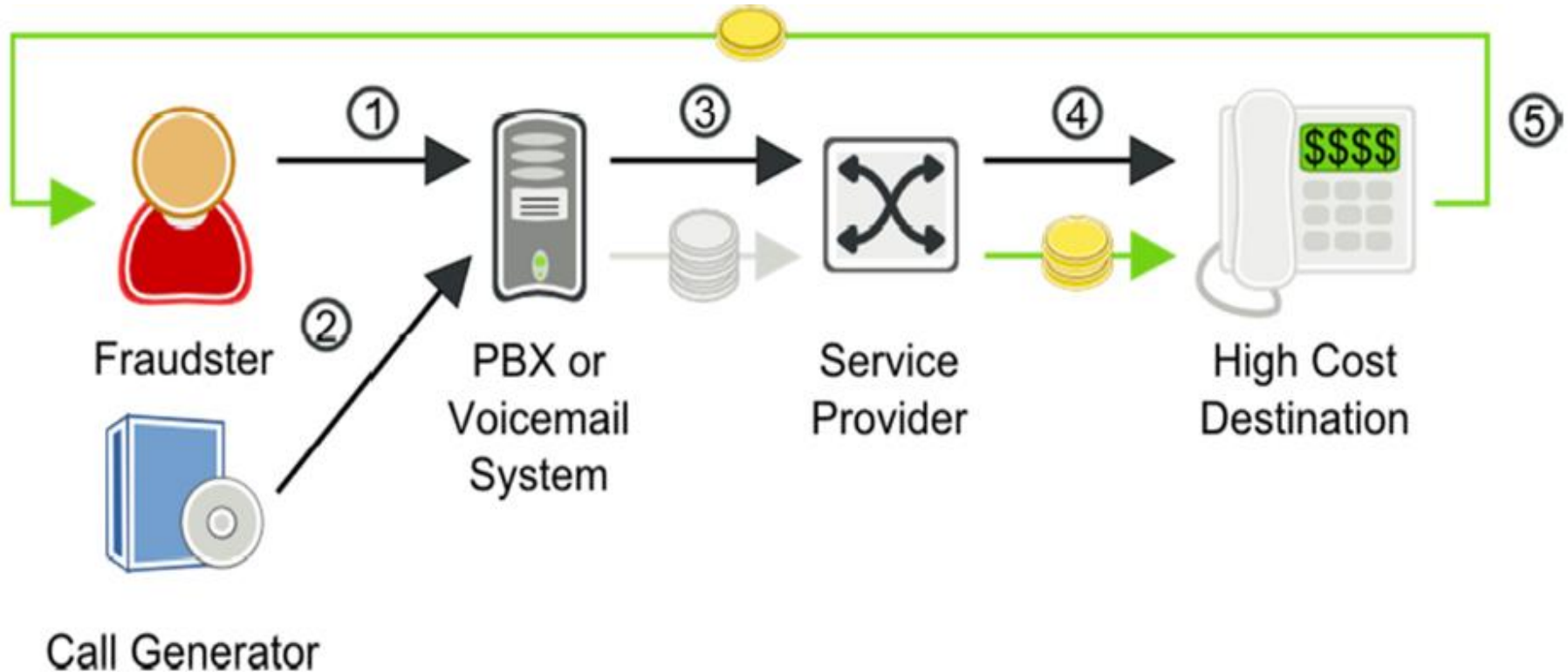
Traffic Pumping Schemes

- Fraudsters often take advantage of lax security practices of a service provider's customers.
- A customer whose network has been compromised will often refuse to pay large fraudulent charges, leaving the service provider to cover the bill.
- Attacks frequently happen over holidays and weekends, when networks are often monitored less closely.

Call Forwarding Fraud

- The **Call Forwarding hack** is a **common form** of VoIP telecom fraud. In this case, fraudsters **gain access** to an enterprise PBX or the **IVR of a voice mail system**.
- They can then **configure call forwarding** to an **expensive long distance destination** to profit from a **revenue sharing deal**. Typically the service provider's **terms of service** clearly state **that the customer is liable for fraudulent calls generated from their phone system**.
- In reality, however, **few customers ever pay for fraudulent calls** and the **service provider bears the financial loss** because their **carrier forces them to pay for fraudulent calls**.

Call Forwarding Fraud



Call Forwarding Fraud

Step	Call Flow	Money Flow
1	Fraudster accesses a PBX or the IVR of a voice mail system, compromises a user's login credentials, and sets the user's account to forward calls to a high cost destination.	
2	Fraudster calls the compromised number over either PSTN or VoIP.	
3	The compromised PBX forwards the call to the service provider's softswitch.	The hacked enterprise technically owes the service provider payment for these calls, but will rarely pay.
4	The service provider switch routes the call to the high cost destination.	The service provider must pay its carrier for the fraudulent, high cost calls.
5		The fraudster has a revenue sharing deal with the high cost destination and receives payment.

Multiple Transfer Fraud

- Multiple transfer fraud is an **enhanced version** of the previously described **call forwarding fraud**.
- In this fraud scenario, the **call is transferred** from the call source **immediately after the destination answers the call**.
- When the **call is transferred**, the fraudulent call is in progress with **two high cost destinations** and the **call source hangs up**. This fraud technique is especially **harmful for several reasons**.

Multiple Transfer Fraud

- Each fraudulent call results in two call legs to high cost destinations.
- Since the call source is no longer in the call, it becomes more difficult to identify the source of the fraudulent calls.
- The hacked call source can repeat the process rapidly, one call at a time, to setup thousands of concurrent fraudulent calls through the service provider's softswitch.
- Most softswitches limit the maximum number of concurrent calls from a single customer.

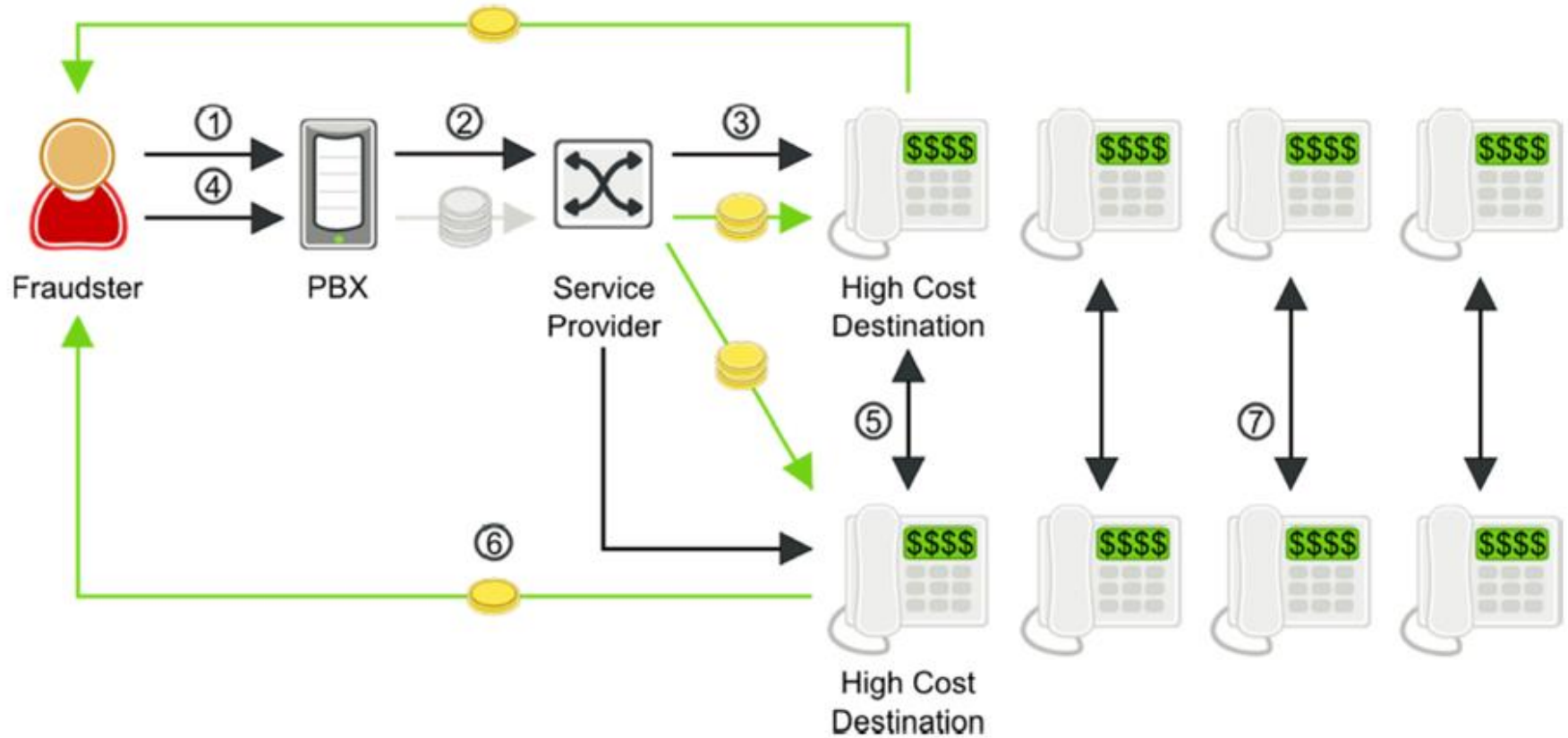
Multiple Transfer Fraud

- However, **this call transfer fraud technique cannot be controlled by concurrent call limits** since the call leg from the hacked phone source and the softswitch is very brief.
- A hacked customer phone with only a single call channel to a softswitch **can generate thousands of concurrent fraudulent calls.**

Multiple Transfer Fraud

- Call transfer is a **sophisticated technique for multiplying the effects of telecom fraud**, while making the fraud **more difficult to detect**.
- Once fraudulent **calls are transferred, they stay up until the carrier shuts it down**.

Multiple Transfer Fraud



Multiple Transfer Fraud

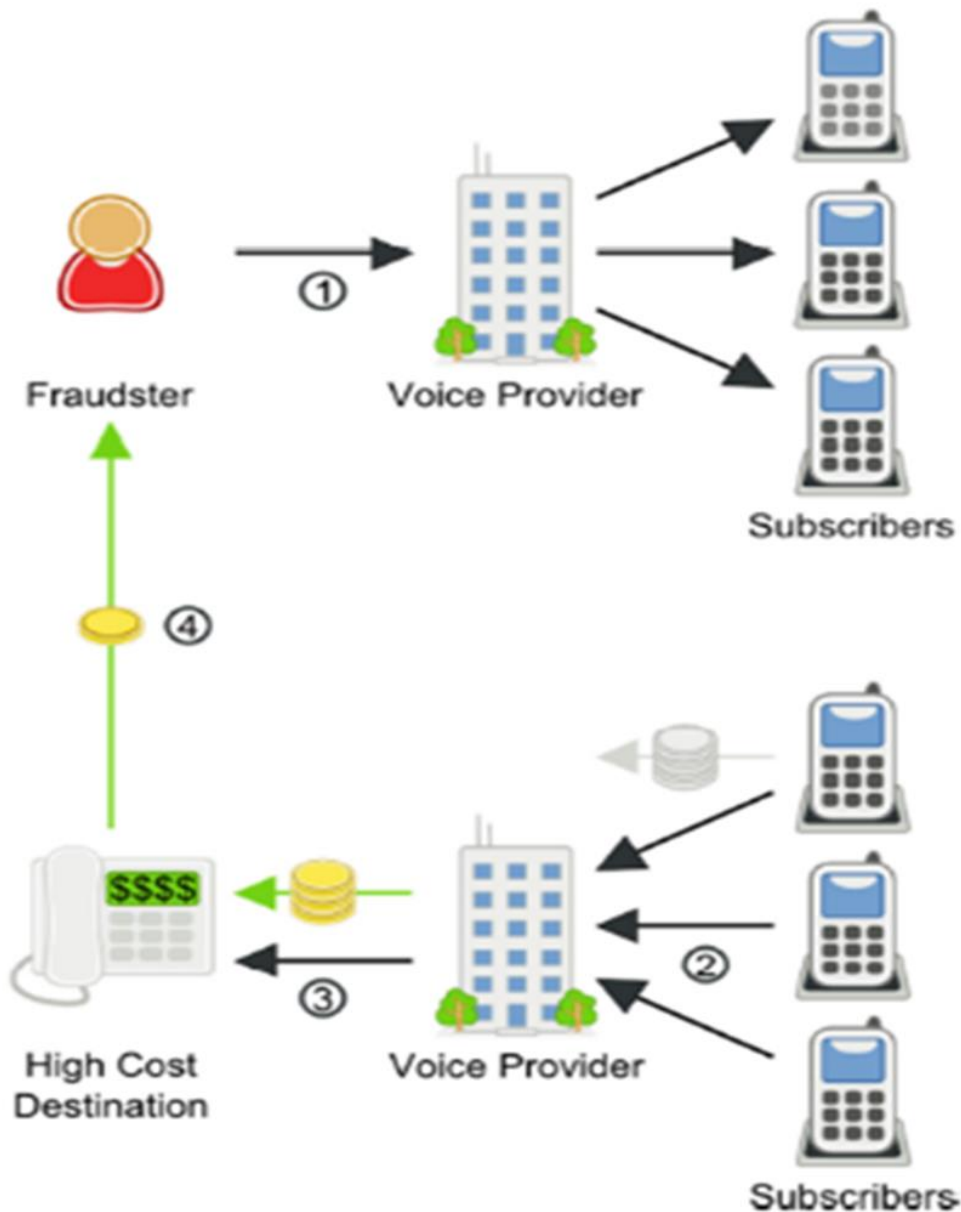
Step	Call Flow	Money Flow
1	Fraudster hacks an enterprise PBX to make calls to high cost destinations.	
2	Compromised PBX sends SIP INVITE to service provider's softswitch.	The hacked enterprise technically owes the service provider payment for these calls, but will rarely pay.
3	Service provider routes call to high cost destination.	The service provider must pay to complete the fraudulent, high cost calls.
4	Fraudster instructs PBX to transfer call to another high cost destination.	The hacked enterprise technically owes the service provider payment for these calls, but will rarely pay.
5	The fraudster hangs up. The call between the two high cost destinations remains in place.	The service provider must now pay for two outbound calls to the high cost destinations.
6		The fraudster has a revenue sharing deal with the high cost destinations and receives payment.
7	Fraudster repeats steps 2-6 to set up hundreds or thousands of simultaneous calls.	

One Ring and Cut (Wangiri) Fraud

- Wangiri, in Japanese, means “**one and cut.**” That is, **one ring and a cut off phone call.** A wangiri phone fraud scheme relies on this single ring method for a quick way to make money.
- A fraudster will set up a computer to dial a large number of phone numbers at random.
- Each **rings just once**, then **hangs up.** This leaves a number as a **missed call on the recipients' phone.**

One Ring and Cut (Wangiri) Fraud

- Users often see the **missed call** and **believe a legitimate call was cut off**, or are simply **curious as to who called**, so they **dial the missed number**.
- This scam is often **used to generate calls to Caribbean countries** that have the **same dial pattern as calls to USA numbers**.
- The number turns out to be a **premium rate number** – anything from **advertising to “free prizes” to sex services**.



One Ring and Cut (Wangiri) Fraud

One Ring and Cut (Wangiri) Fraud

Step	Call Flow	Money Flow
1	The fraudster sets up calls to voice subscribers, but hangs up after one ring.	Because the calls are not answered, the fraudster isn't charged for making the calls.
2	Curious subscribers see a missed call on their phones, and return the call, not realizing that the number is actually a high cost destination.	The subscribers technically owe the voice provider payment for these long distance calls, but will not be happy to pay, as the number looked like a domestic number.
3	Service provider routes call to high cost destination.	The service provider must pay to complete the fraudulent, high cost calls.
4		The fraudster has a revenue sharing deal with the high cost destinations and receives payment.

Schemes to defraud Telecom Service Providers

- Telecom Service Providers are particularly **vulnerable to telecom fraud.**
- Fraudsters are able to **manipulate telecom regulatory systems** to their advantage, and to the **disadvantage of the service provider**, in ways that are **difficult to detect, trace, and prosecute.**

Wholesale SIP Trunking Fraud

- Fraudulent wholesale trunking is a relatively new phenomenon, but one that is growing in popularity and difficult to detect.
- In this scenario, the fraudster is actually making money by **selling wholesale trunking services**, using **stolen credentials** to terminate the calls.

Wholesale SIP Trunking Fraud

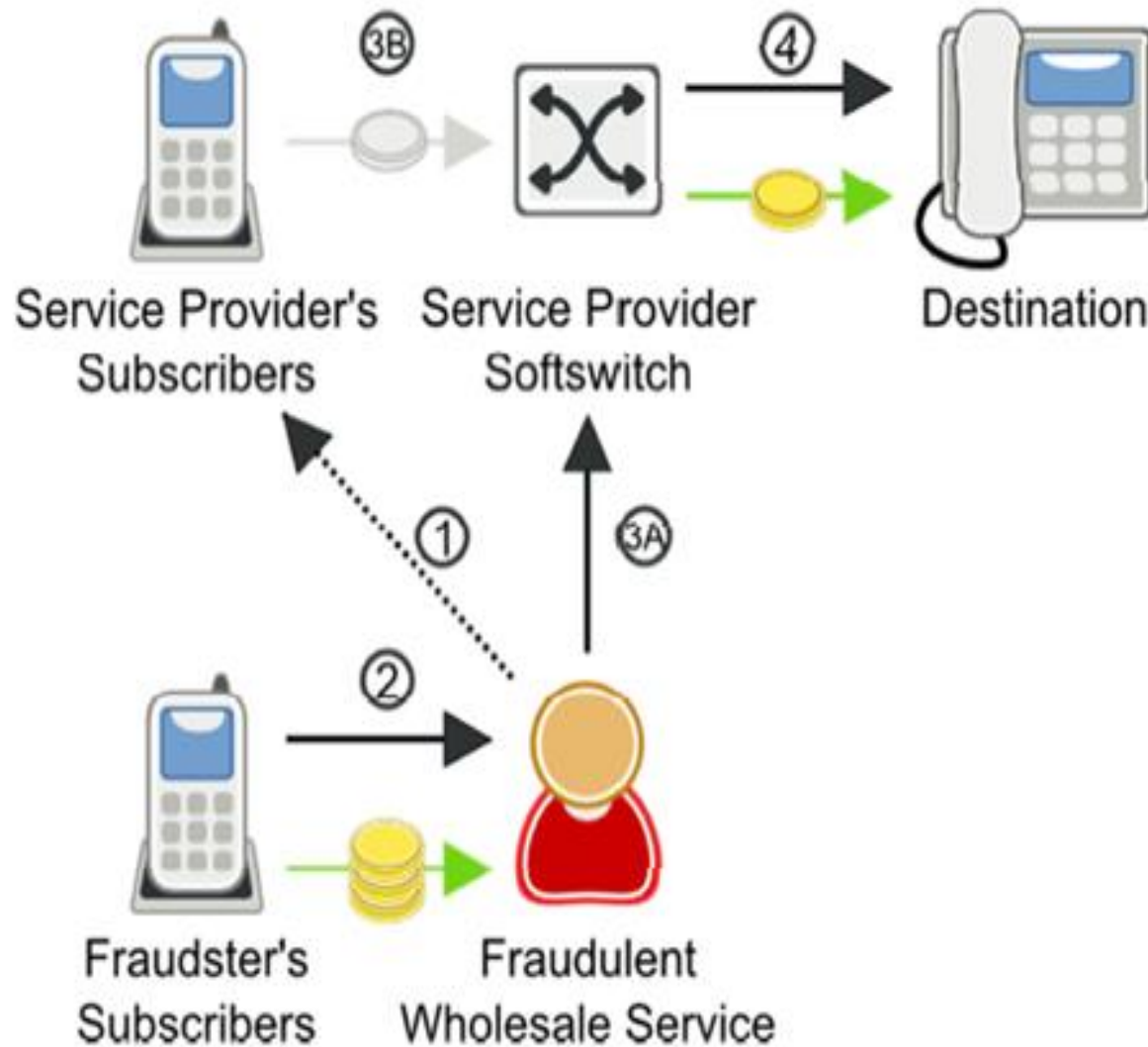
- The key calling signature for this type of fraud is an increased number of apparently random calls.
- The destinations are not particularly high cost, but neither are they cheap. Countries like Vietnam, Laos, and other middle-priced Asian countries show up often.
- The traffic often appears to be to residential numbers.

Wholesale SIP Trunking Fraud

- **Prepaid calling services** are well suited to exploit this type of fraud since there are **no calling numbers** linked to customers.
- The **IP address** of the prepaid calling platform is the only link to **trace the fraudster**.
- Unfortunately, geolocation **cannot always be used to identify the fraudster**. These services can be offered via a tunnel through the Internet that hides the true IP address of the fraudster.

Wholesale SIP Trunking Fraud

- The public IP address of the fraudster's calling platform could be the IP address of a hosted Virtual Private Network (VPN) service while the actual prepaid calling platform is located in a different part of the world.



Wholesale SIP Trunking Fraud

Wholesale SIP Trunking Fraud

Step	Call Flow	Money Flow
1	Fraudster steals credentials of the service provider's subscribers and registers with the service provider's softswitch using those stolen credentials.	
2	Fraudster's subscribers place a call.	Fraudster's subscribers pay for service.
3	(A) Fraudster sends INVITE to service provider's softswitch.	(B) Service provider's subscribers are billed for the call that was placed using their stolen credentials, but are unlikely to pay for the fraudulent calls.
4	Service provider routes calls to their destination.	Service provider must pay to complete the stolen call.

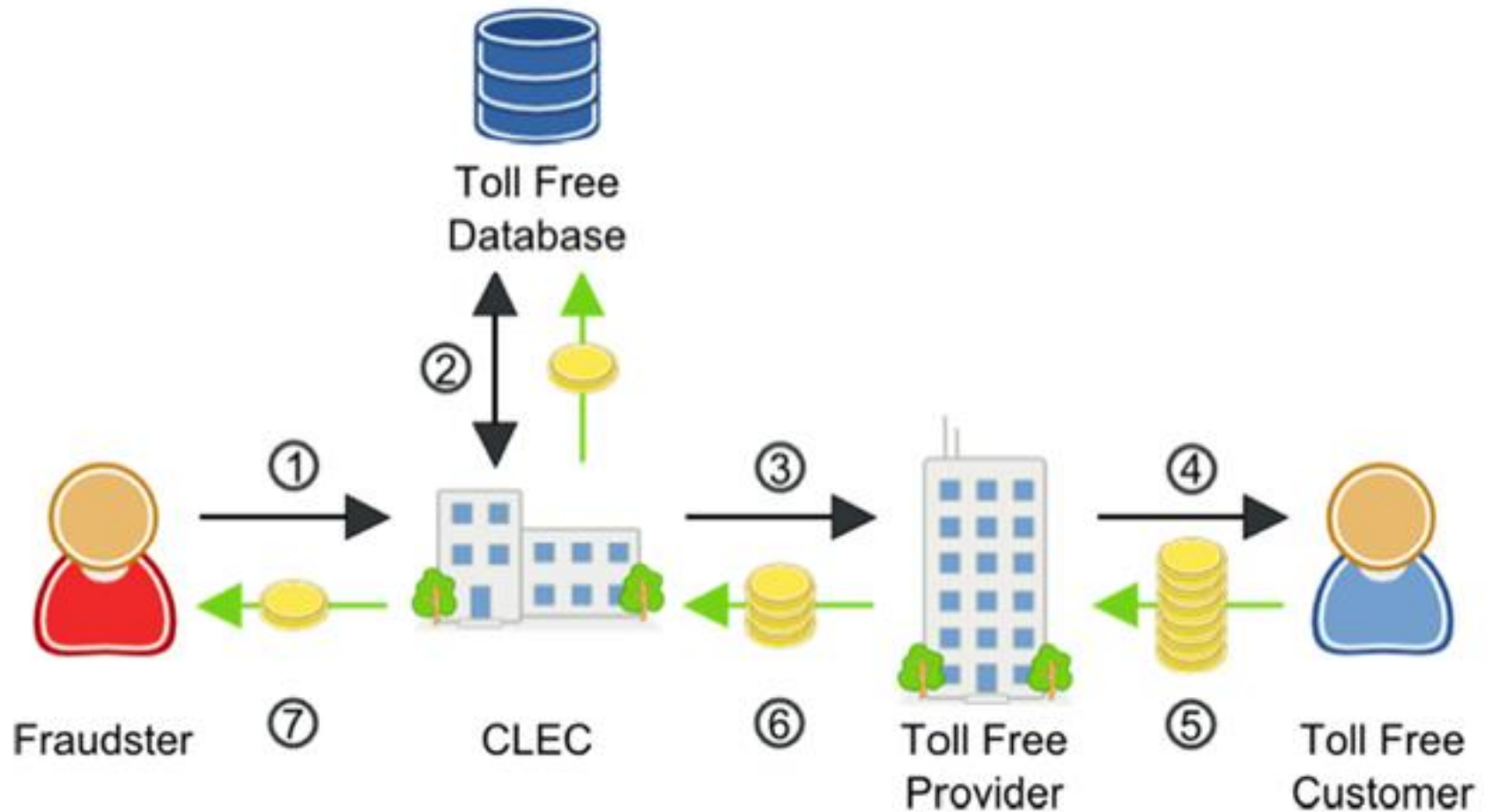
Toll Free Fraud

- **Toll Free fraud** can affect any business that uses a toll free number. These calls are often **left up for hours at a time** and **automated so multiple calls will be made at once**.
- Fraudsters have gotten very sophisticated with this style of fraud, using **different calling numbers for each call** and **only calling during business hours**.

Toll Free Fraud

- They can navigate the IVR system to maintain a call for long periods of time, and **vary the call duration** so that the **calls appear to be real traffic**.
- When **large companies**, like **financial institutions**, are targeted, they frequently **don't even notice the huge charges** racked up by toll free fraud, even though they are expensive, long calls.

Toll Free Fraud



Toll Free Fraud

Step	Call Flow	Money Flow
1	Fraudster makes calls to toll free customer.	
2	CLEC makes a dip to the toll free database.	The CLEC pays to access the toll free database.
3	CLEC routes the call to the designated Toll Free Provider.	
4	Toll Free Provider completes the call to the Toll Free customer.	
5		Toll Free Customer pays the toll free provider the service fee.
6		Toll Free Provider pays the originating access fee to the CLEC.
7		The CLEC shares part of the access revenue with the fraudster who created the bogus toll free traffic.

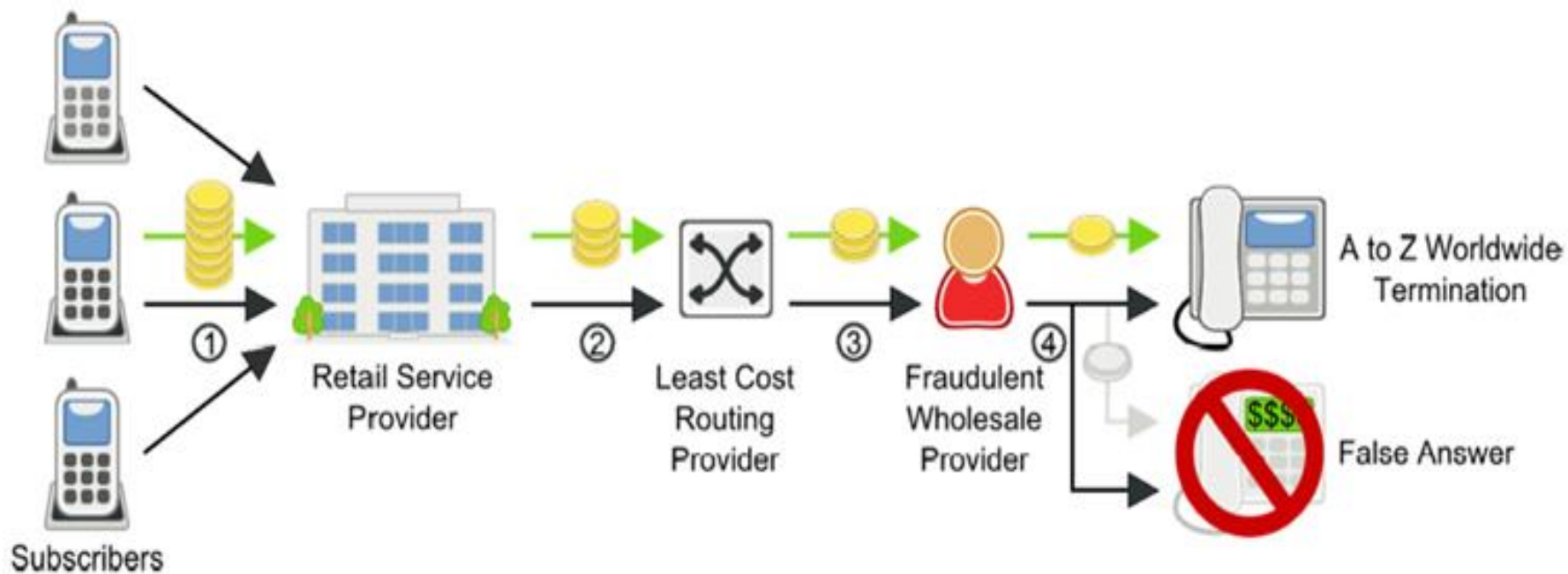
False Answer Supervision

- When a **dialled** phone number is **not in service**, the calling party will **hear a brief recording** telling them so.
- There is **no answer supervision** or **connection between the calling and called party**. Since the call never connects, it is an **incomplete call** and should not be billed.
- However, fraudsters use **false answer supervision** to make these calls **appear as completed calls** which may be billed.

False Answer Supervision

- Perhaps the fraudster has **published rates for terminating calls** without any intention of actually completing the calls.
- Here, service providers will route calls through the fraudster, who, instead of terminating the call, **will play a not in service message** and then bill the **service provider for more than 10 seconds of calling**.
- This type of fraud hurts the **originating service provider** both by costing money, and by hurting their reputation.

False Answer Supervision



False Answer Supervision

Step	Call Flow	Money Flow
1	Subscriber makes a call.	The subscriber pays their retail service provider for service.
2	Service provider routes calls to its wholesale Least Cost Routing Provider.	The retail service provider pays their LCR provider.
3	The LCR provider routes the call to a wholesale provider.	The LCR provider pays the wholesale provider for a completed call to the high cost destination.
4	In most cases, the wholesale provider completes the call, but in some cases, the wholesale provider routes calls to the high cost destination with a “false answer” recording, not completing the call.	The wholesale provider pays nothing, because he did not actually complete the call to the high cost destination.

Location Routing Number Fraud

- Location Routing Number Fraud or LRN fraud works based on the desire of some **service providers to avoid extra charges from LRN “dips.”**
- **Most providers will run an LRN dip to determine the correct LRN for a dialled number. However, some service providers will not perform an LRN dip if the LRN is already in the SIP message.**

Location Routing Number Fraud

- Fraudsters take advantage of this by inserting the **LRN for a relatively cheap terminating destination in their SIP INVITES**, when the call is actually going to a high cost rural destination.
- The service provider **will route and bill the fraudster using the LRN included in the SIP INVITE.**

Location Routing Number Fraud

- The **network** that provides **PSTN termination** will **route and bill for the call to the high cost rural destination using the correct LRN**.
- The service provider will **under-bill** its customer for the call and will have to pay for the **cost of the expensive rural call**.
- In some cases, this can be up to **5x** the price **they billed the fraudster**.

Location Routing Number Fraud



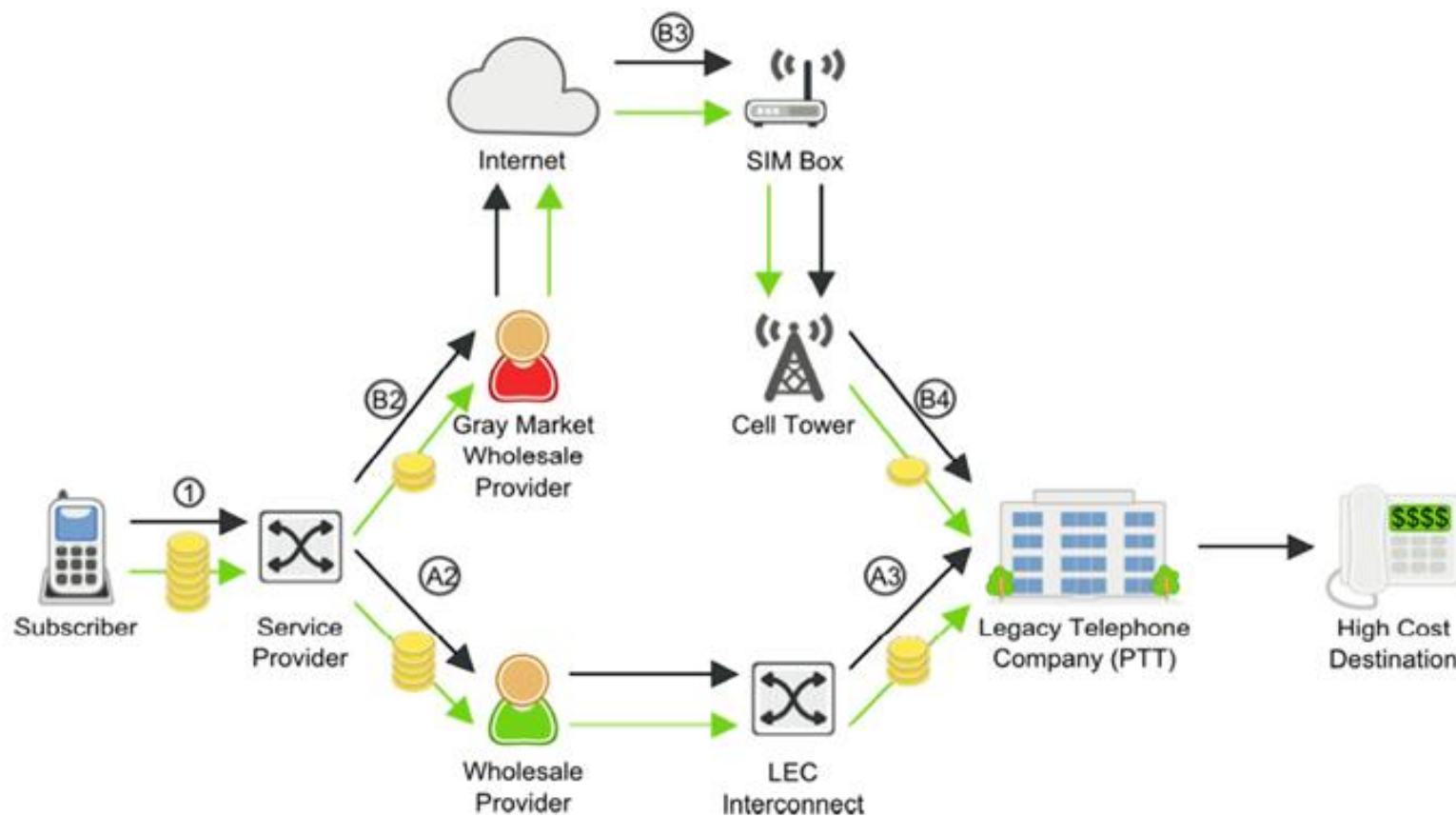
Location Routing Number Fraud

Step	Call Flow	Money Flow
1	Source Network sends a call to a wholesale provider with an incorrect low cost LRN in the SIP INVITE.	Provider charges the Source Network for a call to the incorrect LRN.
2	The provider completes the call.	The correct LRN for the call is more expensive than expected. The wholesale provider loses money, and the Source Network gets below cost termination.

Toll Bypass Fraud

- Bypass fraud is the unauthorized insertion of traffic onto another carrier's network. In many countries, toll bypass for international call termination is criminal fraud.
- This scenario requires that the fraudsters obtain network access which makes international calls appear to be cheaper, domestic calls, effectively “**bypassing**” the normal payment system for international calling.
- One common technique for perpetrating this Interconnect fraud is GSM Gateway fraud, or SIM Boxing which is illustrated in the next slide.

Toll Bypass Fraud



Toll Bypass Fraud

Step	Call Flow	Money Flow
1	Service provider has the choice to route a subscriber's call to a more expensive Wholesale Provider (A) or a lower cost "Gray Market" Provider (B).	Subscriber pays service provider for service.
A2	Service Provider routes call to Wholesale Provider.	
A3		Wholesale Provider pays a toll to the international Legacy Telephone Company (PTT).
B2	Service Provider routes call to a lower cost gray market wholesale provider.	The service provider pays the gray market wholesale provider.
B3	The gray market wholesale provider routes the call through a SIM Box.	
B4	The international call routed through the SIM Box to a cell tower looks like local subscriber traffic.	The gray market wholesale service provider pays a significantly reduced local traffic toll instead of the expensive international toll.

Inter/Intra State Tariff Bypass Fraud

- Bypass fraud is the **unauthorized insertion of traffic onto another carrier's network**. Inter/Intra State toll bypass fraud attempts to bypass the higher tolls of intra-state traffic by making it look like inter-state traffic.



Inter/Intra State Tariff Bypass Fraud

Step	Call Flow	Money Flow
1	Subscriber places an intra-state call.	Subscriber pays the service provider for service.
2	Fraudulent Service Provider changes the calling number of the call so that it appears to be a less expensive inter-state call.	The fraudulent service provider pays the wholesale long distance provider for an inexpensive inter-state call.
3	Wholesale Long Distance Provider routes call to the LEC as an inter-state call.	The wholesale long distance provider pays the LEC for the inexpensive inter-state call.
4	LEC completes the more expensive intra-state call, but charges for a less expensive inter-state call.	The LEC must pay for the more expensive intra-state call and loses money.

Schemes conducted over the telephone

- Criminals of all sorts use **telephony as a tool to defraud consumers and businesses.**
- "**Phone fraud**" is a huge category, and can cover anything from **Nigerian prince style scams** to **identity theft to extortion.**

Account Takeover

- With this type of **telecom fraud**, the fraudster generally attacks something like a **financial institution**.
- Fraudsters will call **financial institutions** and maliciously **impersonate another customer** in order to steal the **contents of an account**.

Telecom Denial of Service (TDoS)

- **Telecom Denial of Service (TDoS)** attacks are similar to traditional data network denial of service (DDoS) attacks.
- In a DDoS attack, unauthorized users **flood a system with too many access requests**, preventing legitimate users from accessing the network.

Telecom Denial of Service (TDoS)

- For TDoS, fraudsters make a **huge number of phone calls**, keeping them up for **long durations**, and **overwhelming the capacity** of an organization's phone network.
- TDoS attacks can **impair a voice network's availability**, but can also be used as a tool for extortion.

Telecom Denial of Service (TDoS)

- TDoS attacks have been in the news recently as a threat to **public safety**, as **fraudsters have taken to using TDoS attacks against hospitals, police stations, and other public services.**

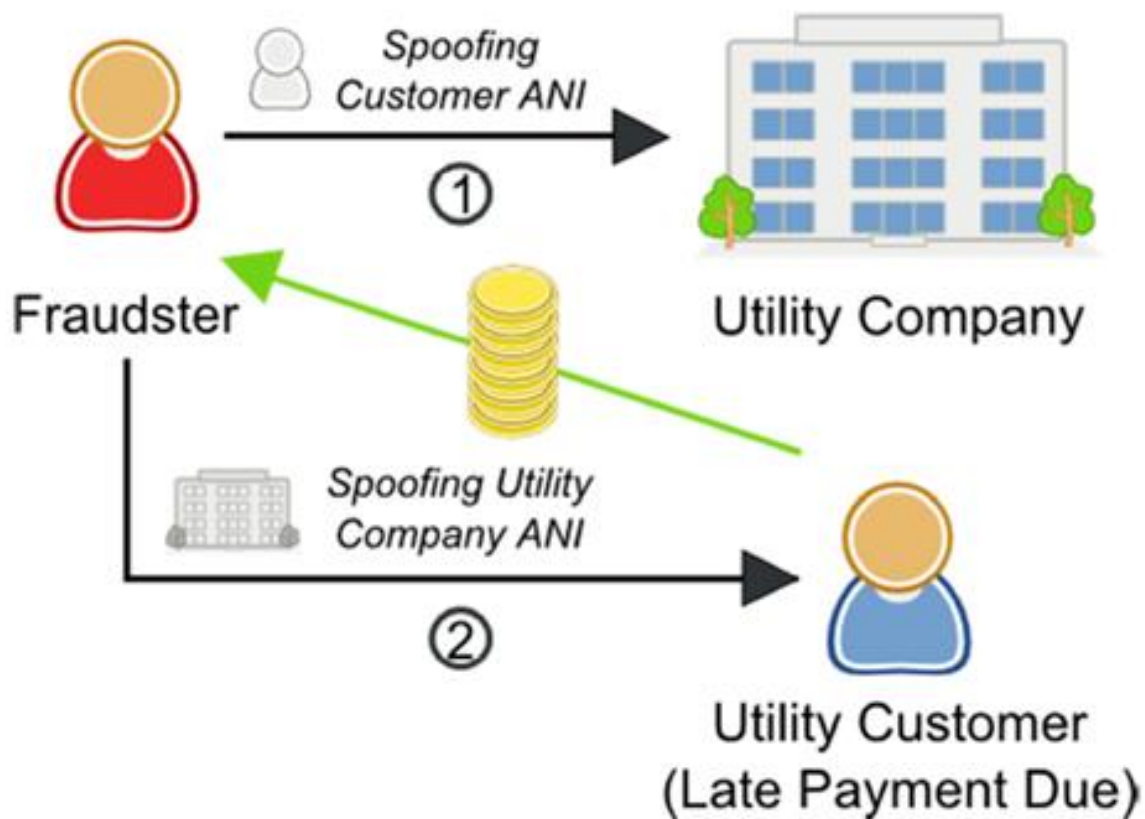
Vishing

- **Phishing** is a form of fraud that uses **email messages with phony addresses, websites or pop-up windows** to gather your **personal information**, which can then be used for **identity theft**.
- A form of phishing that uses the telephone instead of email is known as **Vishing** or "**Voice-Phishing**."

Vishing

- Vishers pose as a legitimate business to attempt to gather information from someone.
- That information can then be used for **identity theft** or other forms of fraud.

Vishing



Vishing

Step	Call Flow	Money Flow
1	Fraudster calls the Utility Company while spoofing the ANI of a customer. The fraudster then navigates the utility's phone system to gather customer data, especially credit balance.	
2	Fraudster calls customers who are behind on their payments while spoofing the utility company's ANI. The fraudster pretends to work for the utility company, and demands payment over the phone in order to get the customer's credit card information.	The fraudster now has access to the utility customer's credit card information and can use it to make fraudulent withdrawals.

Classification of Telecom Fraud

Call Selling

- **Call selling** is the practice of **selling service to customers at below market rates but using another person's system and equipment to deliver that service.**
- The usual practice is to **sell cheap international calls to an expat community.** The community may **well not be aware that the service they are using is illegal** and is generally in **support of cheaper calls back home.**

Classification of Telecom Fraud

Call Selling

- The operator may have to make payments to his international partners as they will have connected a call.
- He will have a potential irate customer who will be experiencing **bill shock** and have the option of writing off all or part of the bill and the possibility of the customer churning.

Classification of Telecom Fraud

Call Selling

- There is **no relationship** between the fraudster and the calls being made.
- **Calling cards themselves are usually just a way of remembering the card and account identity.**

Calling Cards Fraud

Call Selling

- There are many ways in which this information may be stolen including:
- *“Shoulder surfing”*, use of **high-powered binoculars** or **cameras to watch** the user entering the codes. Recording devices have also been used to eavesdrop on numbers spoken to the operator.

Calling Cards Fraud

Call Selling

- *Simple theft* of the card itself.
- *Hacking*, where the fraudster uses repeated attempts to deduce or guess code combinations.
- Once the fraudster has the codes, the illicit use of them can often be carried out from a remote location to minimise the chances of being caught.

Premium Rate Fraud

- **Subscription fraud** can take many guises, but can be divided into two classes, one where people enter the contract with **no desire to pay for service**, and the other where people decide part way **through a contract that they will no longer pay for service**.
- The latter case usually results in a dramatic change in **usage behaviour**. However, the former case has **no usage history to compare the initial heavy usage against**.

Premium Rate Fraud

- In this case additional subscriber information is required to try and assess the risk associated with the subscriber.
- Premium Rate Fraud involves two actions - **the setting up of a Premium Rate Service**, and the **acquiring of a number of phones to call this number**.

Premium Rate Fraud

- The actual mechanism used for perpetrating the fraud will depend upon the **payment scheme** used for the **Premium Rate Service**.
- If the Premium Rate Service **receives a share of the revenue generated for the Network**, then the phones **will make long duration calls to the Premium Rate number**.

Premium Rate Fraud

- If the Premium Rate Service receives money from the network according to the number of calls received by the Service, then the phones will make a high number of short duration calls.
- The phones that have been calling this number will then not have their bills paid.

Premium Rate Fraud

- The signature of such fraud is therefore dependent on the payment scheme used for the Service, but will be a number of high risk phones either making repeated long duration calls or many short duration calls to certain Premium Rate numbers.

Hacking Fraud

- All frauds in this category **generate revenue for the fraudster by breaking into insecure systems, and exploiting or selling on any available functionality.** Examples of such fraud are PABX fraud and Network attack.
- In PABX fraud, a fraudster **repeatedly calls a PABX**, trying to get access to an outside line. Once the fraudster has access to this, they can then dial out, **making high value calls**, whilst only paying for the low value PABX access call.

Hacking Fraud

- Often, such attacks are associated with the use of cloned phones, so that even these low cost legs are not paid for.
- In Network attacks, computer networks are attacked through the access modems that are used for remote management or support.

Hacking Fraud

- Once a modem is **hit**, the fraudster then tries to **break into the network** and **configure certain machines** for his own end.
- Such frauds are characterised by **rapid short calls to the same number in the case of PABX fraud**, or **short calls to sequential numbers in the case of Network fraud**, and it is this behaviour that has to be detected.

Technical Fraud

- All frauds in this category involve **attacks against weaknesses in the technology of the mobile system.**
- Such frauds typically need some **initial technical knowledge and ability**, although **once a weakness has been discovered** this information is **often quickly distributed in a form that non-technical people can use.**
- Examples of such fraud are **Cloning, Technical Internal fraud.**

Technical Fraud

- In cloning fraud, the **phone's authentication parameters are copied onto another handset**, so that the **network believes that it is the original handset that is being authenticated**.
- In Technical Internal Fraud, **fraudulent employees may alter certain internal information to allow certain users reduced cost access to services**.
- The **usage behaviour in these frauds depends on how long the fraud is expected to remain undetected**.

Technical Fraud

- In the situation where the Fraudster believes that the **fraud can be hidden for a long time**, then the best approach would be to **exhibit normal usage behaviour**, as no attention is then drawn to it.
- However, if the fraud has a short lifetime, then the **best approach is to make as much use of the service as possible until it is stopped**.

Procedural Fraud

- All frauds in this category involve attacks against the procedures implemented to minimise exposure to fraud, and often attack the weaknesses in the business procedures used to grant access to the system.
- Examples of such fraud are Sim Swap, Roaming fraud, Voucher ID duplication, and Faulty vouchers.

SIM-Swap



Beware of SIM-Swap Fraud

SIM-Swap involves a fraudster collecting victim's personal banking information and then approaching the victim's mobile operator with fake ID proofs to obtain a duplicate SIM card. The mobile operator deactivates the original SIM card and issues a replacement SIM. With the help of the new SIM card, fraudster does account transactions through mobile banking without victim's knowledge.

SIM-Swap

- ★ Enquire with your mobile operator if you have no network connectivity and are not receiving any calls or alerts for unusually long periods
- ★ Do not disclose your mobile number on social media platforms. Contact your mobile operator immediately as soon as you receive an indication of a probable SIM-Swap
- ★ Do not switch off your cell phone in the event you receive numerous unknown calls. It could be a ploy to get you to turn off your phone and prevent you from noticing a tampered network connection
- ★ Register for both SMS as well as e-mail alerts to stay informed about transactions on your account
- ★ Check your bank statements and online banking transaction history regularly so you can identify any issues or irregularities.

Please visit the '**Safe Banking**' section on our website, www.icicibank.com for more details.

Case Study – SIM Swap

Roaming Fraud

- In the case of **Roaming fraud**, the billing procedure may mean that the **Subscriber is billed a long time after the calls were made**, in which case the **subscriber may no longer be billable**.
- Another aspect of this may be that the **subscriber has been identified as a fraudulent roamer**, but an error in the procedure of terminating **his subscription means that he is able to continue making calls whilst roaming**.

Voucher Fraud

- In the case of **Voucher fraud**, there may be **problems associated with the procedures used to produce, distribute, activate and de-activate the PAYT vouchers.**
- If the voucher information **can be distributed to a number of people who attempt to activate the voucher at the same time**, then if the **procedure provides a time window between the phone account being credited and the voucher being de-activated**, this may allow a number of people to use the same voucher.

Voucher Fraud

- Such frauds usually display normal behaviour, and can only be countered by **tightening up the procedures involved.**

PBX

- PBX (**P**ri**v**ate **B**ranch **E**xchange) systems started out as an **internal company switchboards** where **operators manually directed calls from one person to the next.**
- By the time the 80's rolled around, manual switchboards had been thrown aside, replaced with automatic switchboards that could route the call by itself.

PBX

- Fast forward to today, where PBX technology is taking on a whole new realm, the Internet world.
- **Instead of routing calls through old switchboards and circuits, today's solutions use Internet protocol to exchange information.**

PBX Hacking

- **PBX hacking – the act of breaking into and accessing a company's PBX system and selling long distance/international telephone time to third parties – remains one of the leading types of fraud around the world.**
- It's also nothing new, having first been reported in 2005.

PBX Hacking

- Since then, it has consistently been one of the main computer crimes reported to Fraud investigators all over the world.
- **Telephone hackers can take over insecure PBX systems to make international and long distance calls, listen to voice mail or monitor conversations.**

PBX Hacking

- The main economic reason fraudsters hack PBX systems is to gain access to the trunk lines after which they begin generating as many calls as possible to international premium rate numbers that they own off which the criminal collects 90% revenue.
- Many businesses are unaware that they are responsible for all calls made from their phone system, including any fraudulent calls.

PBX Hacking

- More so, victims of hacked PBX systems are typically unaware of any unauthorized use and unwittingly allow the hackers to “**sell**” the use of their telephone system to others or, far worse give the hackers the opportunity to maliciously reprogram the system.

Fixed Network Fraud

- Network operators around the world use a myriad of **different network configurations to deliver broadband data connectivity** (Table 1).
- However, there are in essence only two substances used for transport in fixed communications networks:
 - ✓ **copper** and **fibre-optic glass**.

Fixed Network Fraud

- Copper carrier systems are further subdivided into thin “**twisted pair**” cables originally designed for voice telephony and thick “**coaxial**” cables with greater capacity, primarily installed for cable television.

Fixed Network Fraud

- There are essentially five possible types based on the distribution of these three carriers in the distribution and “**last-mile**” segments of the network.
- The divisions are not exact, as many of them **depend on how far out to the customer premises the network operator deploys fibre.**

Categories of Fixed Networks

Table 1: Categories of fixed networks

	Core	Distribution	Last Mile³
PSTN	Fibre	Twisted pair	Twisted pair
Cable TV	Fibre	Coax	Coax
Hybrid fibre coax	Fibre	Fibre	Coax
Fibre to the node ⁴	Fibre	Fibre	Twisted pair
Fibre to the home ⁵	Fibre	Fibre	Fibre

Introduction to SS7 and Security

Absence of security in SS7 is identified as a weakness, but not seen as a problem due to the following:

- ✓ Existing trust relationships amongst Telcos
- ✓ Closed networks
- ✓ Only experts are working and monitoring networks

Introduction to SS7 and Security

- Today networks are changing and protection for SS7 is becoming a necessity due to:
 - The opening of the network for various (smaller) interconnect parties and service providers
 - IP access to SS7 networks
 - Less experts available to monitor networks
 - More SMS service providers connecting to network, increasing the possibility of sending wrong messages without any purpose or trying to abuse the network.

Introduction to SS7 and Security

- Today networks are changing and protection for SS7 is becoming a necessity due to:
 - TCAP and protocols based on TCAP are more vulnerable to fraud.
 - Don't need end to end physical connections
 - Used in inter-PLMN communications Preventing SS7-Based Attacks using TCAP Security

SS7 based security threats

Spoofing - Definition:

- ✓ Illegal use of HPLMN SMSC by a 3rd party.
- ✓ An MO SMS with a manipulated A-MSISDN (real or wrong) is coming into the HPLMN network from a foreign VLR (real or wrong SCCP Address).
- ✓ If the billing is made from the SMS-C data, the real subscriber will be invoiced.

SS7 based security threats

Spoofing - Precaution:

- HPLMN can check the originator MSISDN (to verify if it's a real or not).
- HPLMN can check if the VLR location stored in the HLR is in the same range with the requesting SCCP address.

SS7 based security threats

Faking (MT Spoofing) - Definition:

- A fake SMS is originated from the international SS7 network.
- SCCP/MAP addresses are manipulated.
- SCCP/MAP addresses are wrong or copied from a real existing SMSC.
- SMS can be sent to a real subscriber (recovering IMSI) or to a wrong IMSI (only to generate traffic).

SS7 based security threats

Faking (MT Spoofing)

Precaution:

- Controlling access to the SS7 network
- Supervision of foreign SMSC traffic

SS7 based security threats

Spamming - Definition:

- Subscriber receives unwanted SMS.
- Sender can be valid.
- SMS can be billed correctly.
- SMS is submitted by a mobile phone or by a third party connected to the SMSC.
- Only real detection method is customer complaints.

SS7 based security threats

Spamming

Precaution:

- Repetitive content check
- SMS Firewall / SMS Router

SS7 based security threats

Flooding

Definition:

- Massive load of messages to one or more destinations.
- The only parameter is the number of messages sent.
- May cause denial of service

Precaution:

- Supervision of traffic

SS7 based security threats

Mobile Viruses

Definition:

- Unwanted signaling
- Stolen private information

Example:

- Hatihati

Precaution:

- SMS Defence

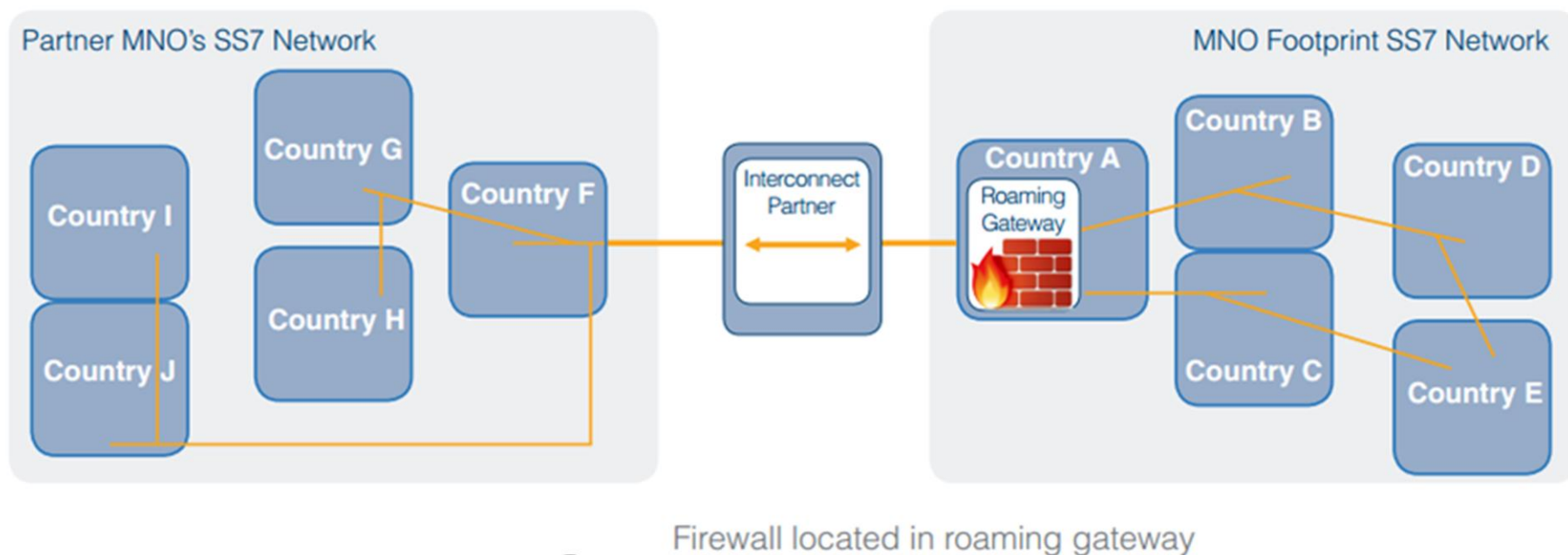
Countering the attack

- There is no way to stop unauthorised SS7 Message Signal Units (MSU) from being injected into networks and so a solution must work by recognising and dealing with them before they can reach their intended destination.
- One way this could be done is by placing a firewall at a network interconnect, for example a Signalling Transfer Point (STP) or International Gateway Exchange, and auditing MSUs as they pass through.

Countering the attack

- Packets flowing through the firewall would be decoded and inspected where configured rules would be applied and traffic flow filtered accordingly.

Countering the attack



Countering the attack

- Filtering rules could be applied at multiple levels of the SS7 stack to include the following parameters:
 - ✓ Application Context
 - ✓ Global Title
 - ✓ PLMN ID
 - ✓ Operation Code

Countering the attack

- Rules could be applied as blacklists, for MSUs to block, whitelists, which block all MSUs of a certain type except those specified and greylists, for events to log.
- By fully decoding MSUs at multiple levels the firewall could recognise spoofed messages, for example, by comparing the calling party digits in the Signalling Connection Control Part (SCCP) layer with those in the Mobile Application Part (MAP) layer.

Countering the attack

- By blacklisting MSUs that contain mismatches between these two layers an operator could block spoofed messages on their network.

Countering the attack

- Returning to the example of the spammer compiling a list of phone numbers, a network operator may decide to use a whitelist to block all ATI requests except those originating from a list of trusted sources.
- When the attacker's ATI requests are received by the firewall they will be rejected when the source address is not found on the list.

Countering the attack

- However, ATI requests from whitelisted sources will still be passed on.

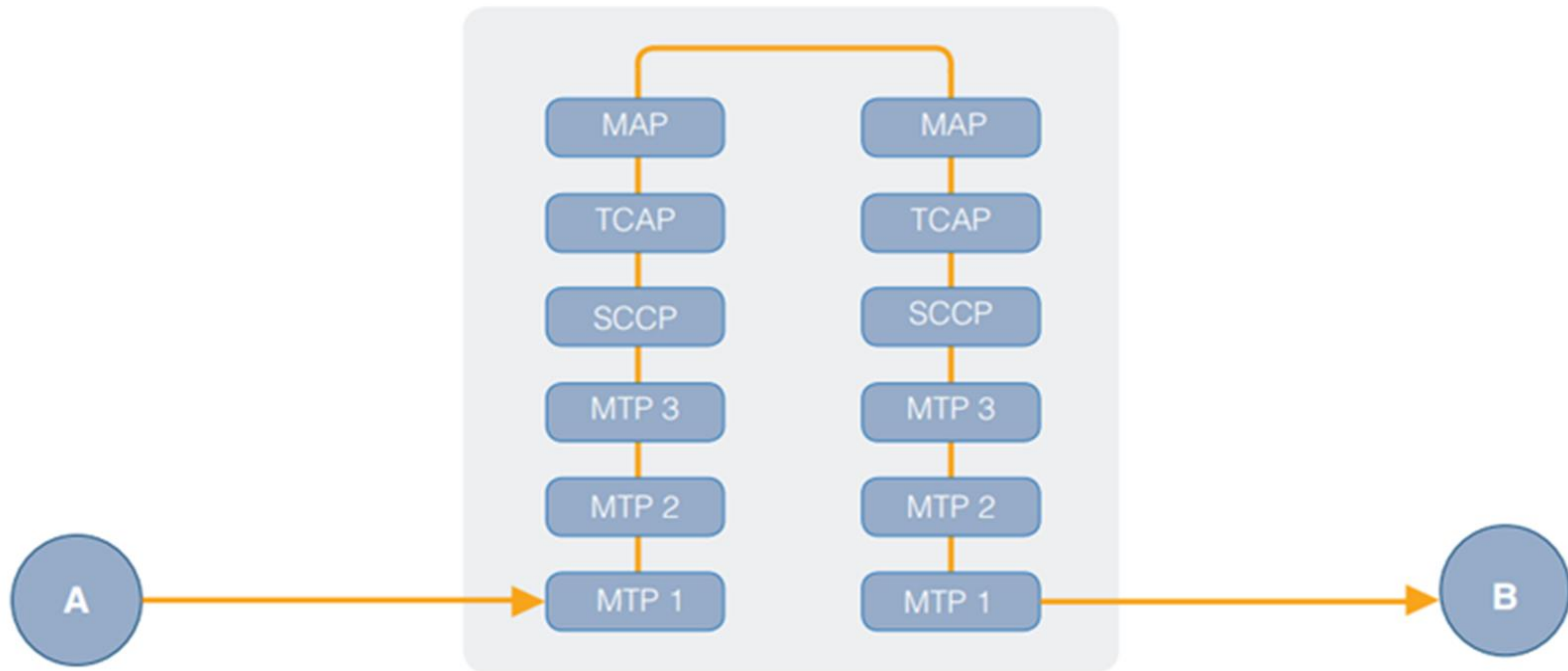
Protecting mobile networks from SS7 attacks

- Network operators' own data could also be utilised by the firewall to enable it to make more sophisticated judgements regarding MSU routing. If, for instance, the firewall had access to a subscriber's HLR 'velocity checks' could be performed to detect unauthorised MSUs.
- A location update from Australia for a subscriber who two minutes previously reported he was in France would clearly be illegitimate.

Protecting mobile networks from SS7 attacks

- A firewall with access to the relevant database could be programmed to recognise this and act accordingly.

Protecting mobile networks from SS7 attacks



Full decode of MSU for multi-layer filtering

Protecting mobile networks from SS7 attacks

- To further improve the efficiency of the firewall data could be collected in order to build a picture of statistically normal network behaviour.
- A node that regularly receives large numbers of update Location requests, for example, is likely to be an HLR.

Protecting mobile networks from SS7 attacks

- If all of a sudden mt-forwardSM MSUs are detected as coming from this node it's likely they would be unauthorised as an HLR would not ordinarily send such a message.

Protecting mobile networks from SS7 attacks

- Building a picture of normal network behaviour in this way could be used to detect International Revenue Share Fraud attacks (IRSF).
- IRSF attacks work by attaining a premium rate phone number or range of phone numbers from an international revenue share provider, who shares a percentage of the income generated from calls made to these numbers, and fraudulently initiating calls to them.

Protecting mobile networks from SS7 attacks

- Calls can be fraudulently initiated in a number of ways – SIM theft, international call forwarding, hacking Private Branch Exchanges (PBX) – but will often have a distinct signature when made for the purpose of IRSF.

Protecting mobile networks from SS7 attacks

- Known IRSF number ranges could be added to black or grey lists and suspicious activity, particularly long bulk calls to a single number, could be flagged as potentially fraudulent.
- By recognising suspicious activity like this as quickly as possible the firewall would enable the network operator to take action to block the fraudulent calls, saving money that would otherwise go to fraudsters.

Mobile Network Fraud

- Mobile security is the protection of smartphones, tablets, laptops and other portable computing devices, and the networks they connect to, from threats and vulnerabilities associated with wireless computing.
- Mobile security is also known as wireless security.

Fraud in Wireless domain

In 2012 enterprise mobile security survey polled 487 IT security professionals and IT managers. The survey found the following top five mobile security concerns:

- 1. Device loss was the top concern. If an employee leaves a tablet or smartphone in a taxi cab or at a restaurant, for example, sensitive data, such as customer information or corporate intellectual property, can be put at risk.

Fraud in Wireless domain

According to Marcus Carey, a security researcher at Boston-based compliance auditing firm Rapid7 Inc., such incidents have been behind many high-profile data breaches.

Fraud in Wireless domain

2. Application security was the second-ranking concern. One problem is mobile apps that request too many privileges, which allows them to access various data sources on the device.

- According to Domingo Guerra, president and co-founder of San Francisco-based Appthority Inc., many mobile apps -- especially free ones -- are built with ties to advertising networks, which makes contacts, browsing history and geolocation data extremely valuable to application developers.

Fraud in Wireless domain

- As Guerra put it, "Developers want to monetize, consumers want free apps and then ad networks will pay developers to get all of that juicy data from their users."
- According to survey respondents, leaked corporate contacts, calendar items and even the location of certain executives could put the company at a competitive disadvantage.

Fraud in Wireless domain

- Another concern is malicious or Trojan-infected applications that are designed to look like they perform normally, but secretly upload sensitive data to a remote server.

Fraud in Wireless domain

3. Device data leakage was the third-ranking mobile security issue. Nearly all of the chief concerns identified in the mobile security survey, from data loss and theft to malicious applications and mobile malware, are sources of data leakage.

- While most corporate access privileges on mobile devices remain limited to calendar items and email, new mobile business applications can tap into a variety of sources, if the enterprise accepts the risks, said mobile security expert Lisa Phifer.

Fraud in Wireless domain

- Increased corporate data on devices increases the draw of cybercriminals who can target both the device and the back-end systems they tap into with mobile malware, Phifer said.
- "If you're going to put sensitive business applications on those devices, then you would want to start taking that threat seriously."

Fraud in Wireless domain

4. Malware attacks were the fourth-ranking mobile security concern. A new report from Finland-based antivirus vendor F-Secure Corp. found the vast majority of mobile malware to be SMS Trojans, designed to charge device owners premium text messages.
- Experts say Android devices face the biggest threat, but other platforms can attract financially motivated cybercriminals if they adopt Near Field Communications and other mobile payment technologies.

Fraud in Wireless domain

- An F-Secure analysis of more than 5,000 malicious Android files found that 81% of mobile malware can be classified as Trojans, followed by monitoring tools (10.1%) and malicious applications (5.1%).

Fraud in Wireless domain

5. Device theft was fifth on the list of top concerns. Smartphone theft is a common problem for owners of highly coveted smartphones such as the iPhone or high-end Android devices.

- The danger of corporate data, such as account credentials and access to email, falling into the hands of a tech-savvy thief, makes the issue a major threat to the IT security pros who took the survey.

Common Telecom Frauds

Clip on

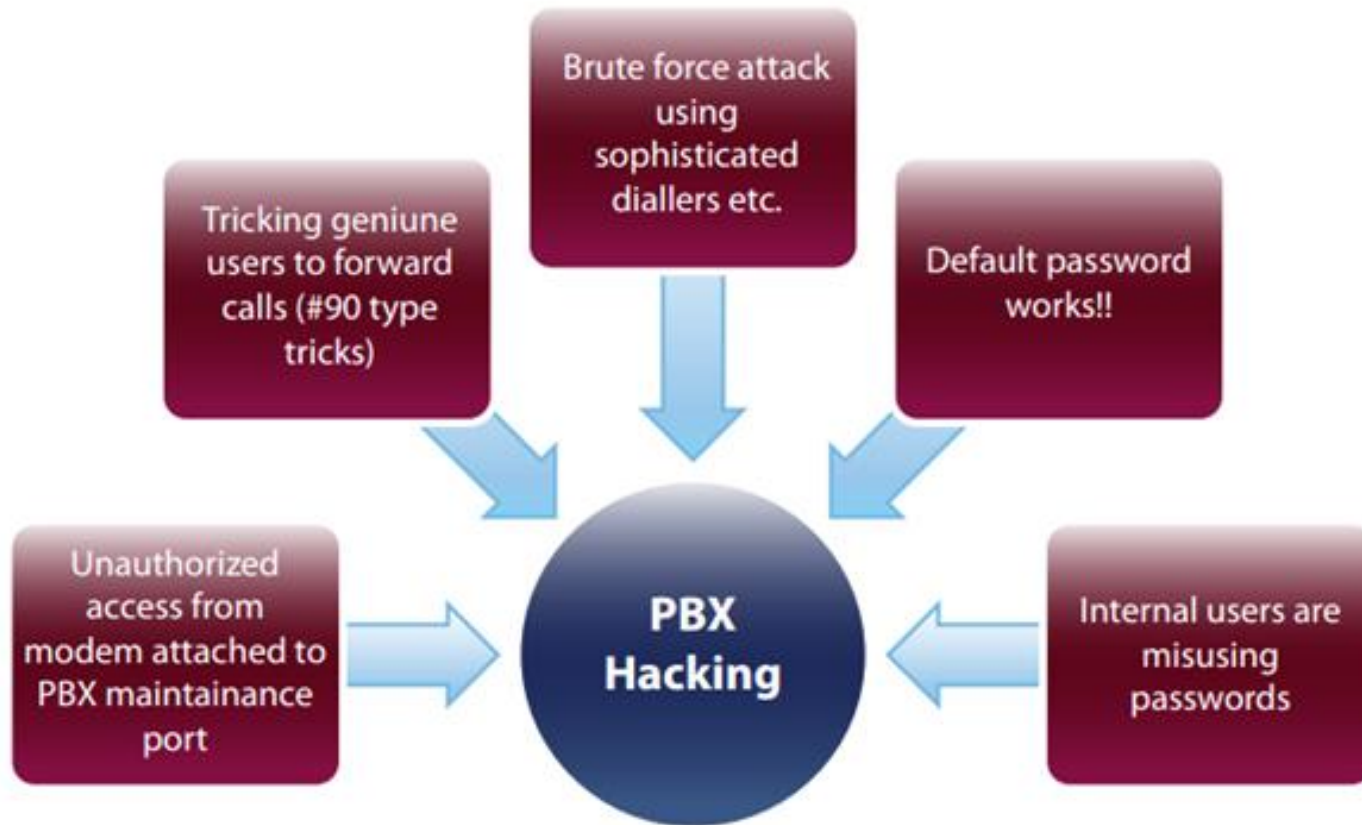
- Illegal parallel connection on the subscriber line and make someone else pay for the calls.

Boxing Fraud

- Illegal stressing of national or international channel associated signalling systems.

PBX Hacking

Popular methods of hacking PBXs are summarized in diagram below



Brute Force Attack

- Typically, the PBX security is breached via the toll-free Direct Inward System Access (DISA) number.
- Many PBXs allow dial-through, wherein a person calling into the PBX can access an external line by using appropriate passwords and control sequences. Large corporates use this feature extensively.

Brute Force Attack

- Fraudsters hack into the PBX, obtain passwords and once a password is retrieved, use the PBX to generate outbound calls.
- “**War dialling**” is one of the techniques used for obtaining passwords. It involves the fraudster trying to break PBX code using an auto dialler, which keeps on dialling same number in a sequence making an exhaustive search of passwords until it breaks through.

Default passwords

- One of the **largest contributing factors in PBX hacking and misuse is careless PBX installation and poor configuration, leaving default user and maintenance port passwords** in place (fraudsters know the default passwords for the various switch vendors).
- PBX fraud commonly occurs when the **customer fails to change the default password or do not change passwords frequently**. Default passwords can be found online in the relevant PBX user manuals etc.

Default passwords

- Telco and PBX vendors should advise corporate customers to changes all **default settings and passwords**.
- This will **prevent easy hacking opportunities for fraudsters**.

Internal Enemy

- Many cases of PBX hacking **result from insiders or vendors who disclose the phone numbers, IDs and passwords necessary for breaching PBX security.**
- Sometimes the **users may get hold of passwords by unauthorised means and use the corporate lines for making personal calls or colluding with external fraudsters to help in PBX hacking.**

Internal Enemy

- **Strict security Policies** should be in force for PBX password control.
- The **physical security of PBXs and phone extensions** is also an important factor to consider in **avoiding misuse of PBXs**.

Social Engineering

- The old traditional (wired) phone scam involving the 90# buttons on corporate telephone lines is still around.
- Employees of a corporation using a PBX line from their desk, receives a call from someone claiming to be a telephone company employee **investigating technical problems with line, or checking up on calls supposedly placed to premium rate services or other countries from your line.**

Social Engineering

- The caller asks the employee to aid the investigation by **either dialling 90#** (or similar combination) or **transferring him/her to an outside line before then hanging up the telephone receiver.**

Social Engineering

- By doing this the **employee will be enabling the caller to place calls that are billed to the corporate telephone account.**
- This attack **only works on few PBXs today.**
- **Social engineering** is another common technique used for **obtaining passwords.**

Service Port

- PBX hackers may also **target modems** attached to the **service PORT of a PBX**. The facility is provided by PBX manufacturers to allow remote support of the PBX.
- Typically, the **connection should be opened only when an authorized request goes from the PBX customer to the PBX vendor**, but many PBX customers **keep the connection always open and therefore prone to attack**.

Unauthorized disclosure of information

- **Loss, misuse, modification, or unauthorized access to sensitive information can adversely affect the privacy or welfare of an individual, trade secrets of a business or even the security and international relations of a nation depending on the level of sensitivity and nature of the information.**

Unauthorized amendment of data

- The unauthorized changing of data before or during their input to a computer system.
- Examples are **forging** or **counterfeiting documents** and ex- changing valid computer tapes or cards with prepared replacements.

Denial of Service (DoS) attack

- In computing, a denial-of-service (DoS) attack is an attempt to make a machine or network resource unavailable to its intended users, such as to temporarily or indefinitely interrupt or suspend services of a host connected to the Internet.

Cloning

- Cloning is the best-known type of telephone fraud, afflicting analogue networks in particular. Cloning is the practice of programming the identity of a legitimate phone into another phone.
- The details of its identity are usually obtained either by eavesdropping on its interaction with the base station or by stealing it.

Cloning

- Calls are then billed to the owner of the legitimate phone. Cases of multiple clones of the legitimate phone have been reported. This clearly multiplies the resultant financial exposure.
- At some point, the legitimate owner protests and is issued with a new identity, with the previous one being barred.

Cloning

- To counter this, criminals have a variant on cloning called “tumbling”, whereby a phone is programmed with the identities of many other phones (99 in one case).
- Each time a call is made, the phone rotates between its identities, lessening the chance of detection and ensuring that the phone will work until all the accounts are barred.

Cloning

- Cloned phones are often sold with a guarantee that they will work for a given number of months - if the clone is detected and the account is barred the supplier will replace it free of charge in the guarantee period.

Q & A



**E.R. Ramesh, M.C.A., M.Sc., M.B.A.,
98410 59353, 98403 50547
rameshvani@gmail.com**

Backup slides

- SS7 – Signaling System No.7
- HPLMN – Home Public Land Mobile Network
- SMST – Short Message Service Technical